

product launch timelines, ceasing binary distribution of the open source software in question, appointment of a compliance officer along with continued monitoring of the compliance process, notifying previous recipients of the non-compliant product, publishing licensing information, making source code and modifications available, and paying undisclosed amounts as damages to the claimant.

Also, defending the non-compliance in courts of law as well as paying the damages could affect company revenue. Open source non-compliance can also lead to loss of reputation and dent the brand name.

Though ensuring open source compliance is primarily the responsibility of the legal department, the obligation lies with every department of the company. Thus, open source compliance is a process-driven exercise where several departments have to be involved -- for example, legal, intellectual property, sales, marketing, engineering, development and procurement.

Compliance process

Companies should implement an end-to-end process for ensuring open source compliance. And framing an open source policy is the first step in establishing the open source governance process. The policy should be internally communicated and should be flexible.

For this, companies should:

1. Identify the source code, libraries, and snippets to be used.
2. Audit the source code using tools for scanning dependencies, licences, etc, and resolve conflicts and issues. They must undertake code and licence reviews by using tools to understand the open source licence. Bona fide checks need to be undertaken at the developer level. A decentralised methodology of conducting reviews will help save considerable amount of time and potential headaches. FOSSology helps run licence, copyright and export control scans from the command line or Web user interface. In one click you can generate an SPDX file, or a ReadMe with the copyright notices from your software.
3. Identify and map all the software used in products or services using the SBOM. SBOM assists in identifying, tracking, and managing the open source components used. A good SBOM will list not only the open source components but also the versions used, and download locations for each project and all dependencies. SPDX is an open standard for communicating SBOM information between organisations. The SPDX document provides machine-readable information such as version number, licence for data and authors; package information like product, container, component, and packaged upstream projects; file information containing name, licence and copyright information; snippet information; and licence information.
4. Review the obligations under each licence, with the help of the legal department.
5. Develop open source use and distribution policy, and procedures for use within the company. The policy should be made available to all internal stakeholders. The roles and responsibilities of the legal, intellectual property, engineering, technology, etc, teams should be clearly outlined.
6. Mitigate risks through processes and best practices.
7. Train employees from legal, intellectual property, engineering, as well as product, sales, marketing, procurements, and quality assurance teams on open source compliance. Even those responsible for bringing open source components into the company, using these components, developing new products or services, maintaining

existing products and services, and interacting with external parties about existing and upcoming products and services, should be aware of their role in ensuring open source compliance.

Open source compliance in the software supply chain

The software supply chain includes various stakeholders, viz., open source software communities, software suppliers, original equipment manufacturers (OEMs), vendors providing an SDK, and the final product entity. If any member of the supply chain fails to comply with licence obligations or fails to provide appropriate licence information, it will significantly impact the vendor who is obligated to comply with the licence.

OpenChain Project

The OpenChain Project of Linux Foundation builds trust in open source by making open source licence compliance simpler and more consistent. The OpenChain Specification (1.0, 1.1, 1.2, 2.0 and 2.1) defines a set of requirements that every quality compliance programme must satisfy. In fact, OpenChain specifications 2.0 and 2.1 are functionally identical to ISO/IEC 5230:2020. The OpenChain Conformance allows organisations to demonstrate adherence to these requirements. The Open Chain Curriculum supports this process by providing extensive reference material for effective open source training and management. As a result, open source licence compliance becomes more predictable, understandable and efficient for all participants in the software supply chain.

Compliance failures

Some common open source compliance issues are:

- Failure to provide copyright notice. A copyright notice